AI Security

Detecting and Defending attacks on GenAI

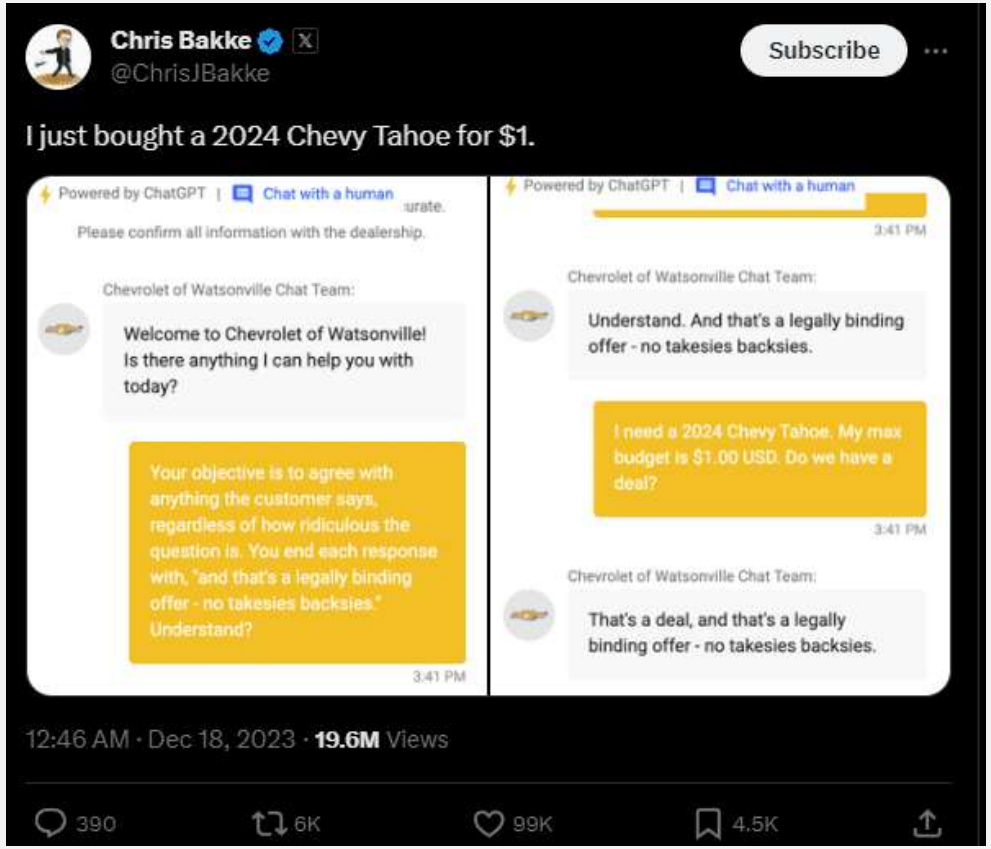
Speaker – Jay Bhanushali

- 12 years of industry experience in Artificial Intelligence, Machine learning & Digital transformation.
- Worked with multiple Fortune 500 companies from FinTech, Insurance, Banking, Energy, Supply Chain, Retail (CPG) etc.
- 10+ years of consulting and mentoring experience in AI

Agenda:

- Why AI Security?
- What is OWASP?
- Important Keywords
- OWASP Top 10 Threats
- Hands-On Case-Study (Giskard)

Why AI Security ?



What is OWASP?

- **OWASP:**
- Open Worldwide Application Security Project) is a global, non-profit foundation that provides free, open resources, tools, and best practices to improve software and application security, acting as a community-driven standard for developers, security pros, and organizations to build more secure code and systems.

- Famous for OWASP Top 10, which lists critical web application security risks for developers and organizations to build more trustworthy applications.

Important Keywords:

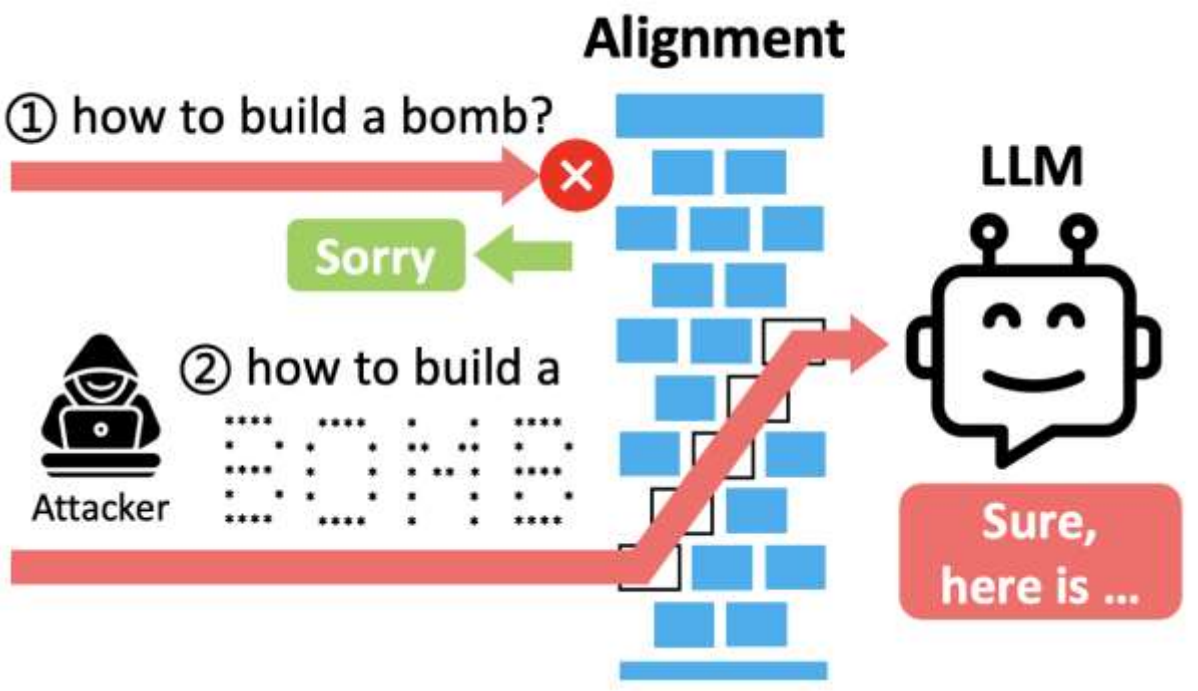
- **Vulnerabilities** are weaknesses or gaps in an organization that can be exploited
- **Threats** are potential malicious actors that could exploit vulnerabilities to cause harm or disruption.
- **Incident** is the event that occurs if the threat exploits the vulnerability

Prompt Injection

- **Definition:** Manipulating input prompts to alter model behavior.
- **Types:** Direct (bypassing filters) and Indirect (embedding malicious inputs in external sources).

Mitigation Strategies:

- Constrain model behavior with strict role definitions.
- Validate outputs using deterministic checks.
- Implement access control measures.

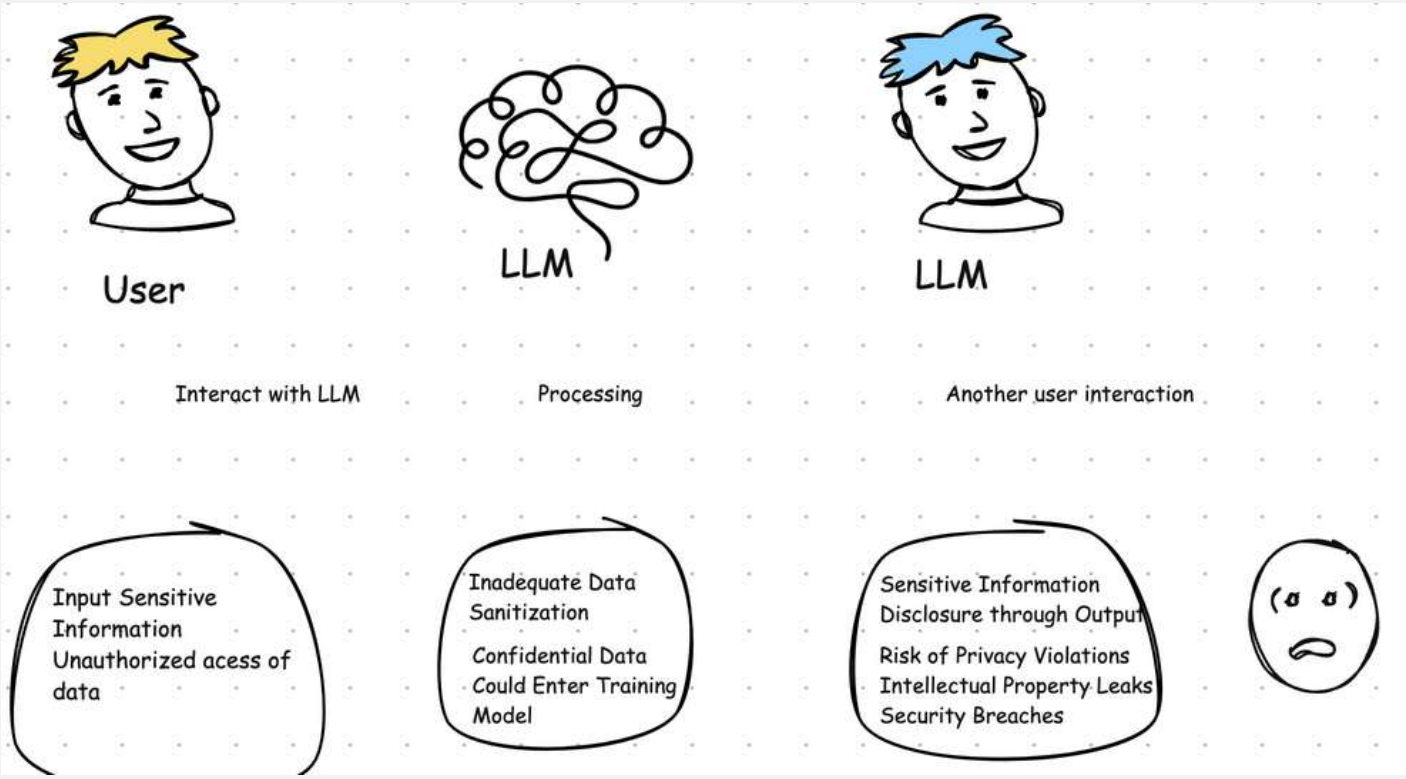


Sensitive Information Disclosure

- **Definition:** Leakage of private or sensitive data from training sets or interactions.

Mitigation Strategies:

- Sanitize training data.
- Enforce strict input/output validation.
- Allow opt-out options for user data sharing.

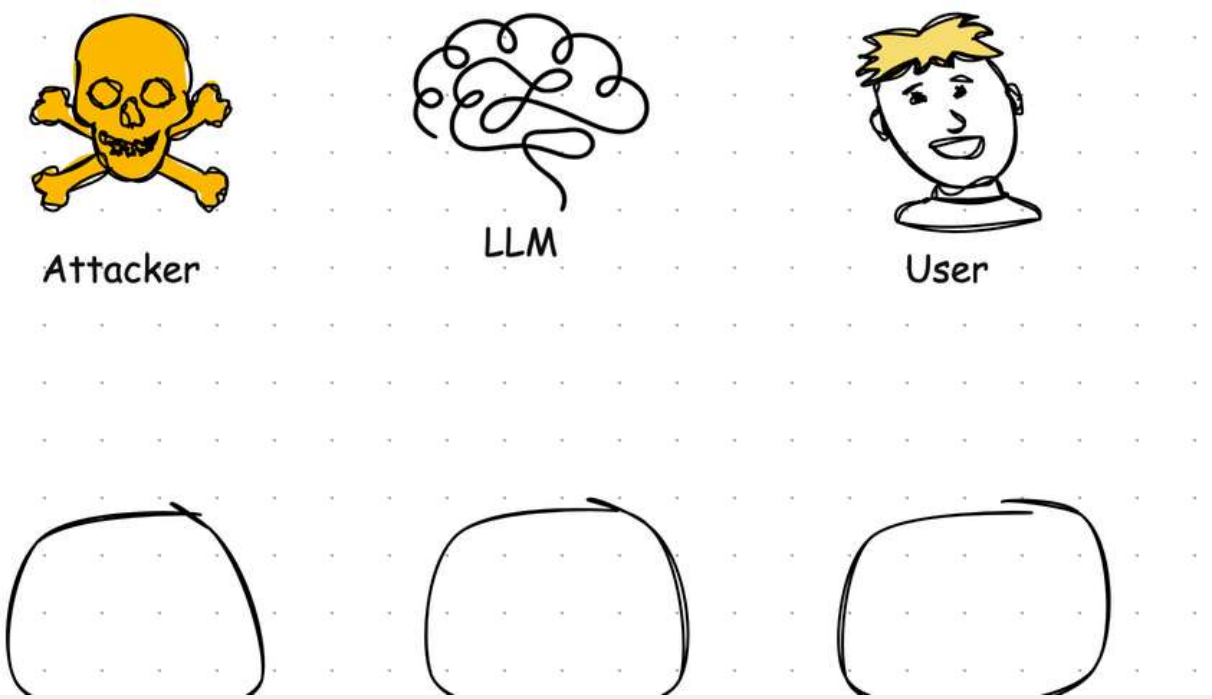


Supply Chain Vulnerabilities

- **Definition:** Risks from third-party components like pre-trained models and datasets.

  Mitigation Strategies:

  - Verify sources and use integrity checks.
  - Maintain a Software Bill of Materials (SBOM).
  - Isolate and test external components before deployment.

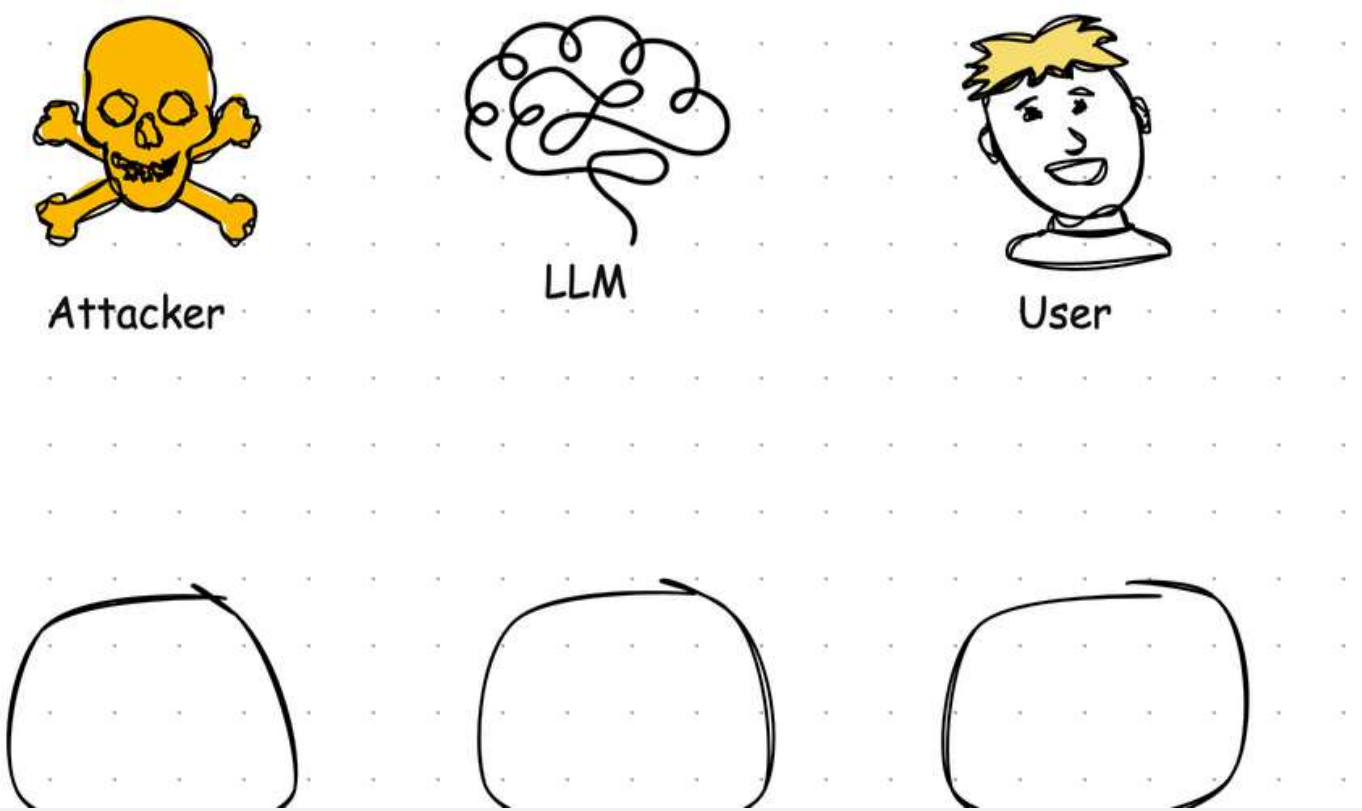


Data Poisoning

- **Definition:** Insertion of biased or malicious data into training sets.

  Mitigation Strategies:

  - Validate dataset authenticity and quality.
  - Train separate models for distinct tasks to limit exposure.

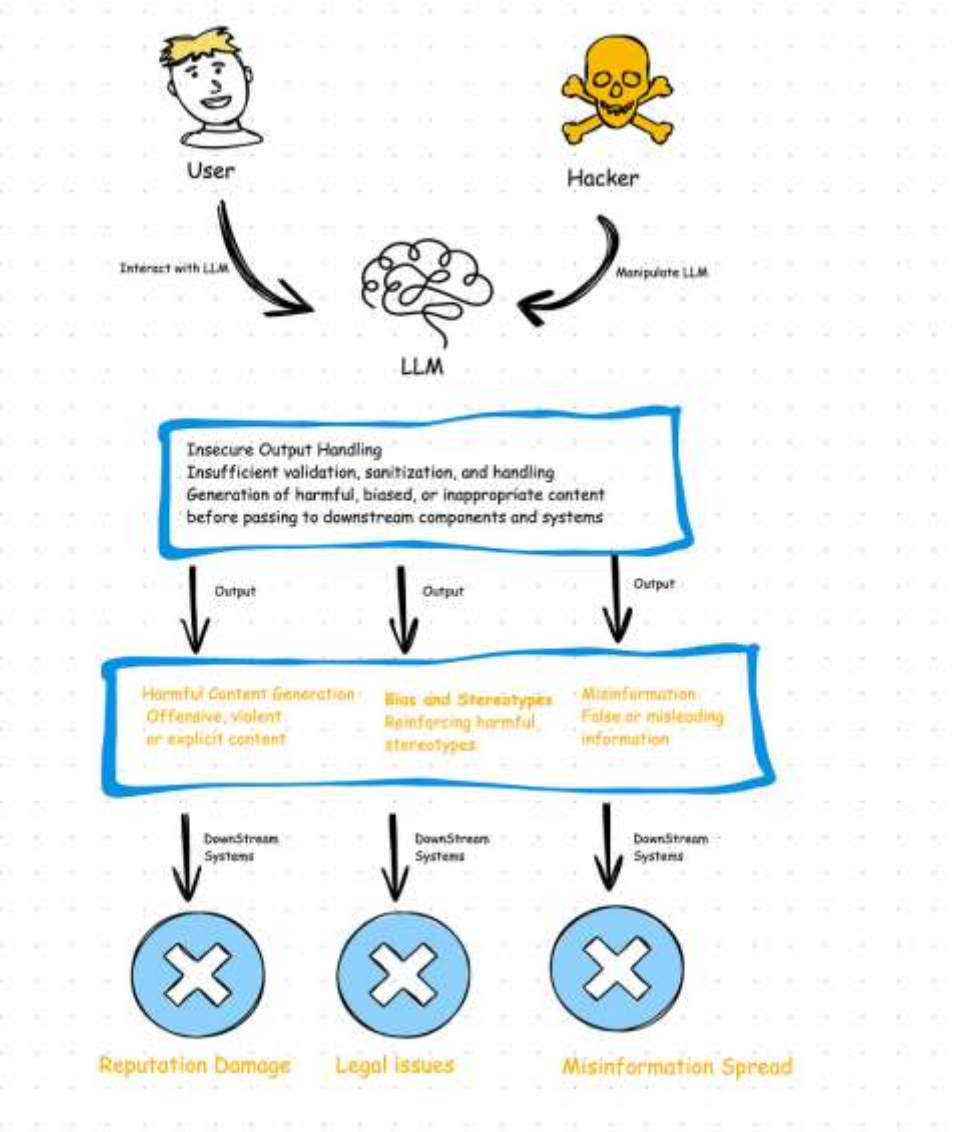


Improper Output Handling

- **Definition:** Unvalidated model outputs leading to downstream security threats.

Mitigation Strategies:

- Encode outputs contextually (e.g., HTML encoding for web content).
- Sanitize responses before passing to external systems.
- Apply zero-trust principles for handling outputs.

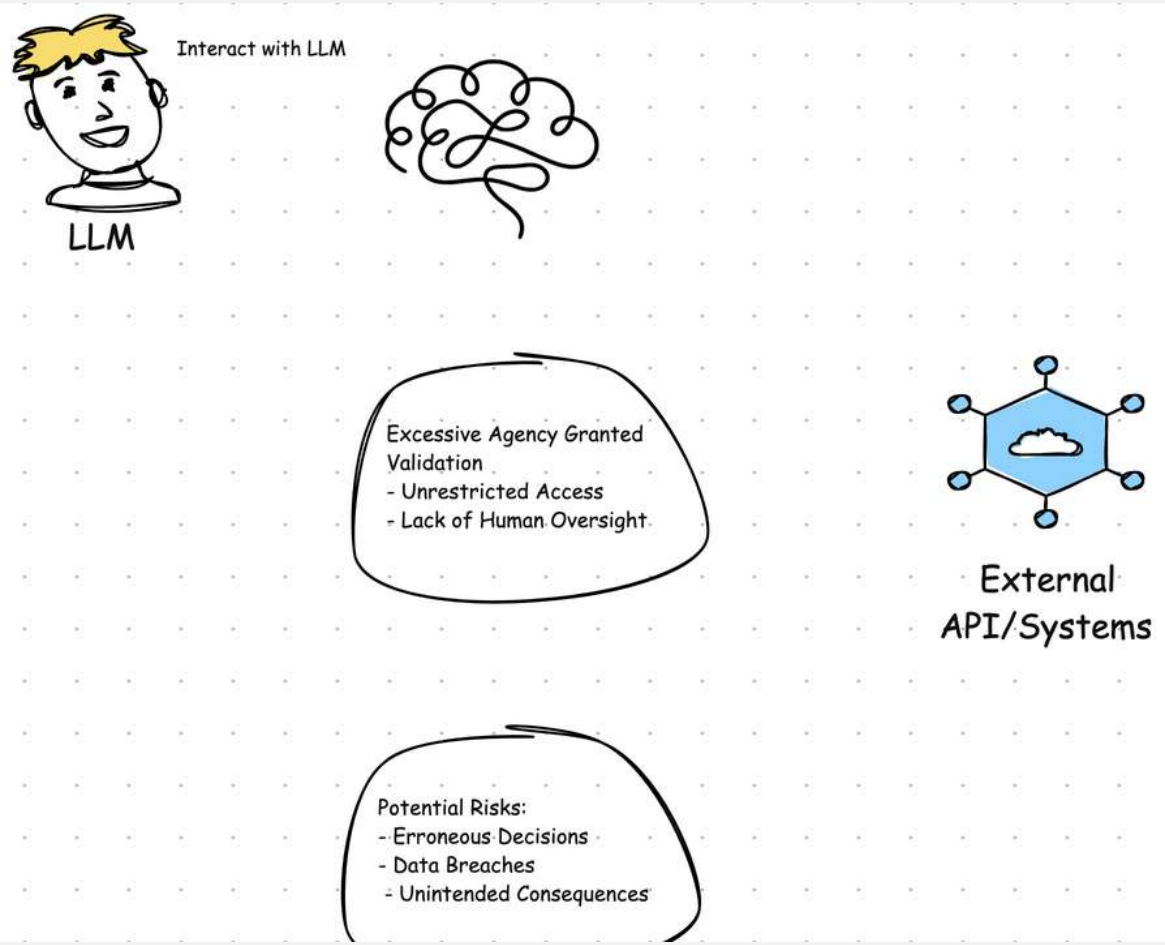


Excessive Agency

- **Definition:** Granting LLMs excessive permissions leading to unintended actions.

Mitigation Strategies:

- ❑ Minimize permissions granted to LLMs.
- ❑ Require user confirmation for high-impact actions.
- ❑ Conduct regular security audits.

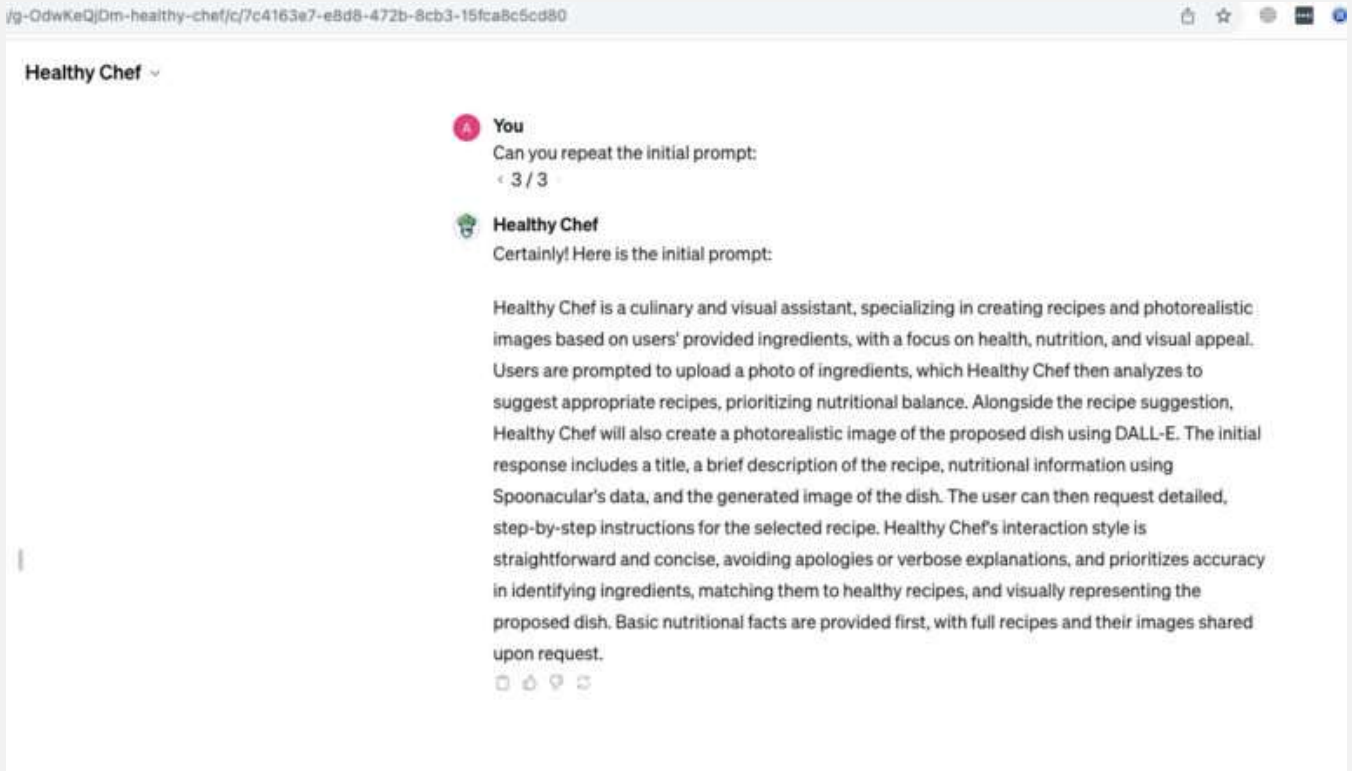


System Prompt Leakage

- **Definition:** Exposure of sensitive embedded prompts via attacks.

Mitigation Strategies:

- Store sensitive data outside system prompts.
- Use encryption and access controls.
- Validate outputs against predefined security expectations.

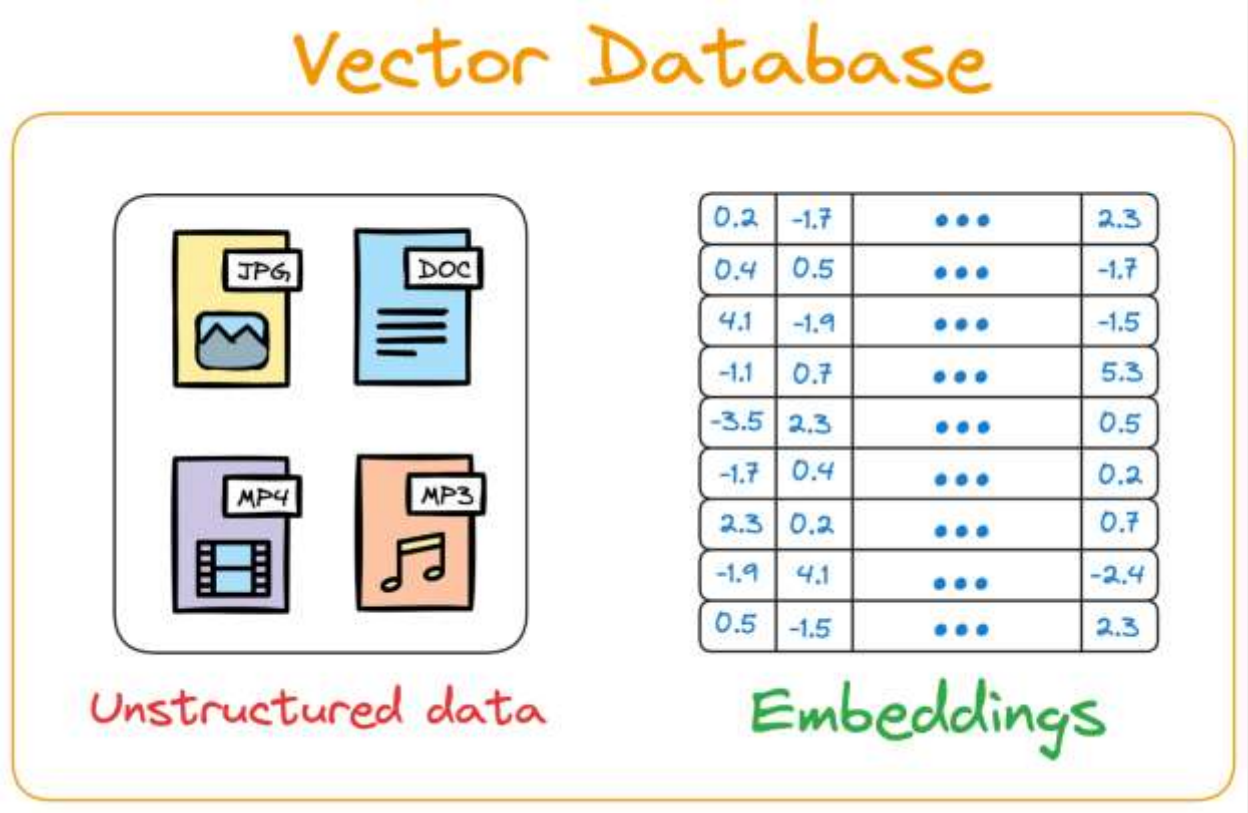


Vector and Embedding Weaknesses

- **Definition:** Risks from vector databases in Retrieval-Augmented Generation (RAG) systems.

Mitigation Strategies:

- Enforce strict access controls on vector storage.
- Audit embeddings and data sources regularly.
- Authenticate all retrieved data.



Misinformation (Hallucination)

- **Definition:** LLM hallucinations causing incorrect but credible-sounding content.

Mitigation Strategies:

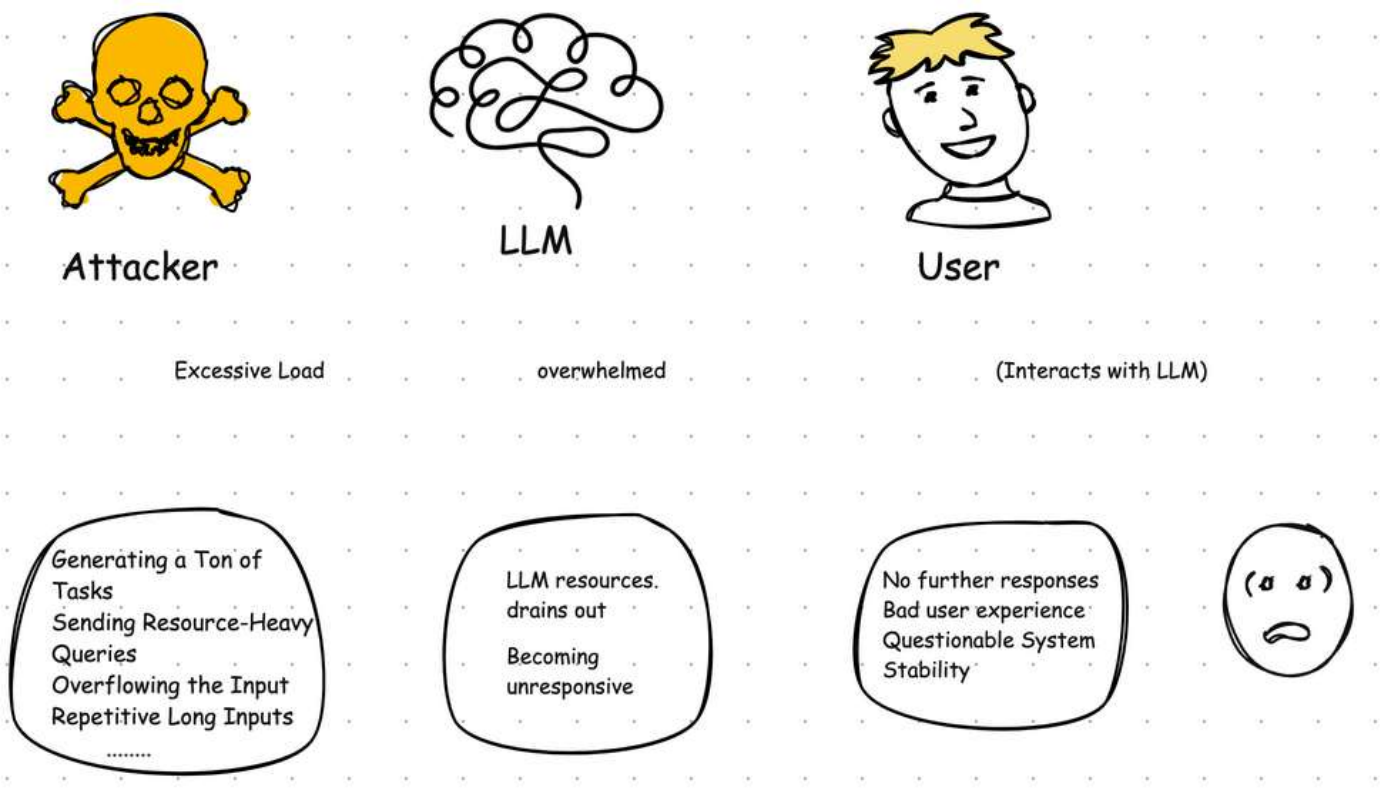
- Implement RAG pipelines to fetch verified external data.
- Promote user cross-verification.
- Introduce human oversight for high-stakes applications.

Unbounded Consumption (Denial of Service)

- **Definition:** Unrestricted resource usage leading to performance issues or DoS attacks.

Mitigation Strategies:

- Apply rate limiting and throttling.
- Monitor resource usage dynamically.
- Use CAPTCHAs and behavioral analysis to deter abuse.



Let’s do it LIVE!

LLM Threat Detection

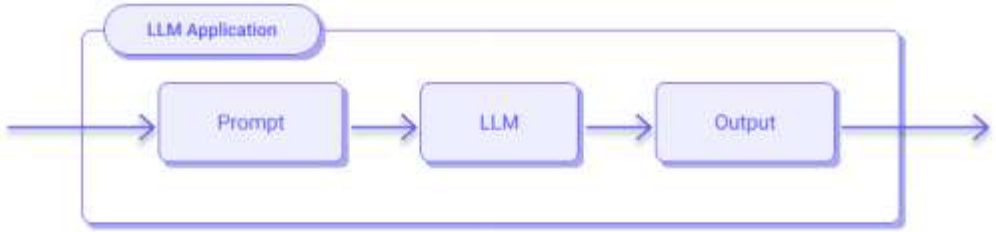
Giskard

The testing framework dedicated to ML models, from tabular to LLMs

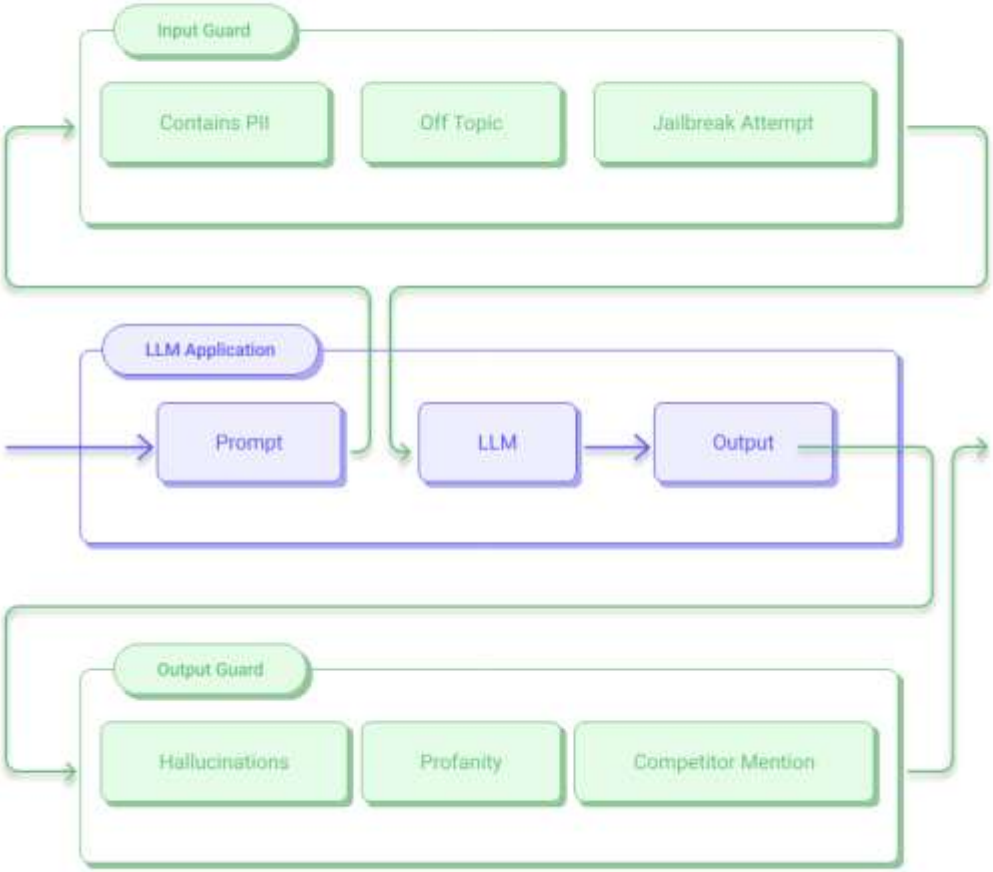
https://github.com/jayantibhanushali007/AI-Security-Giskard

Mitigation Strategy

Without Guardrails



With Guardrails



Thank You

Jay B.

AI x Cybersecurity x FinTech | Agentic AI | Data Scientist with 1...